PRODUCTION AUDIT · REMEDIATION REPORT

Reward Jar

Resolution of every user-reported defect and the code-level remediation of the external production-readiness audit — QR scanning reliability, loyalty-engine concurrency, email-only authentication, and small-screen layout integrity — verified end to end and deployed to production.

Commit **e0b5d3b** · main
Deploy Vercel · production · live
Date 25 October 2026

Table of Contents

1. Executive Summary 2

2. User-Reported Defects — Resolutions 2

2.1 QR scanning did not work on iPhone . . . 2

2.2 The Scan screen was confusing . . . 3

2.3 Greeting showed the wrong text for unnamed users . . . 3

2.4 Mobile-number sign-in removed . . . 3

3. Audit Findings — Remediation Matrix 4

3.1 How the concurrency fixes work . . . 5

3.2 How the loyalty engine treats visits now . . . 5

4. Layout Integrity and Responsive Repair 6

5. Verification and Test Evidence 6

5.1 Browser end-to-end session . . . 7

6. Deferred Items and Recommendations 7

7. Deployment Record 8

1. Executive Summary

This report documents the remediation work carried out on the Reward Jar platform on 25 October 2026, in response to two inputs: a set of defects reported directly by the product owner from real device use, and an external production-readiness audit of commit **bcaa609** that rated the project 6/10 and listed fourteen prioritised findings (F01 through F14). The session covered diagnosis, code repair, automated and browser-based verification, and a production deployment that is now live.

All four user-reported problems were fixed and verified: QR photo scanning now works on iPhones (the primary reported failure), the scan screen was redesigned around a single clear "Scan QR" action, the home greeting is correctly time-aware and no longer addresses unnamed users as "there", and authentication is now email-only, matching the launch configuration. On the audit side, twelve of the fourteen findings received code-level fixes in this session; the remaining two are policy or infrastructure items that require product decisions or external access, and they are documented with rationale in Section 6 rather than silently skipped.

12 / 14	31 / 31	4 / 4	0 px
audit findings fixed in code	backend tests passing	user-reported defects resolved	horizontal overflow at 320 px

Verification was layered: a clean TypeScript compile and ESLint pass, the full backend end-to-end suite (31 assertions covering OTP authentication, earning, redemption, approval and analytics) executed against a freshly seeded database, and a scripted browser session that signed in, exercised the scan screen, and decoded an actual QR photograph through the new decoder. The release was committed as **e0b5d3b**, pushed to GitHub, built successfully by Vercel, and confirmed live on the production URL with no console errors and no horizontal overflow at small viewports.

2. User-Reported Defects — Resolutions

The product owner tested the production site on a personal iPhone and reported four problems against the Scan tab, the greeting, and the sign-in form. Each report was traced to a root cause in code, fixed, and re-verified in a real browser session. Table 1 summarises the chain from report to resolution.

2.1 QR scanning did not work on iPhone

The scanner previously relied exclusively on the browser-native `BarcodeDetector` API and showed an honest error message on browsers that lack it. iPhone Safari does not implement that API, so every attempt to scan a counter QR failed on the device the product actually runs on. The fix adds **jsQR**, a pure-JavaScript decoder, as a universal fallback: photos are drawn to an offscreen canvas and decoded from raw pixel data, with automatic retries at 90, 270 and 180 degrees so counter photos taken at an angle

still resolve. The native detector remains the fast path on Chromium browsers, and camera capture semantics are unchanged.

2.2 The Scan screen was confusing

The old screen led with a large "Have a code? Paste it" card that competed with the primary action and referenced internal URL formats. The redesign makes "Scan QR" the single dominant button, and demotes manual entry to a compact "Have a code instead?" card with a one-line input and a submit button. Explanatory copy now speaks in customer language ("Point your camera at the shop's Reward Jar QR code") and the troubleshooting helper is preserved below.

2.3 Greeting showed the wrong text for unnamed users

Two defects were intertwined here. First, the greeting was computed once per render; customers who kept the app open across a time-of-day boundary could see a stale greeting, which is why "Good morning" appeared at incorrect hours. Second, when no display name was available the headline rendered the literal fallback string "there", reading like an unwanted "Hello there". The greeting is now recomputed on a 30-second interval and on tab-visibility changes, and unnamed users are addressed as "Friend".

2.4 Mobile-number sign-in removed

The sign-in form offered a Mobile/Email channel toggle, but no SMS provider is connected for launch, so the mobile path could not deliver codes. The audit independently flagged this as a customer-experience defect ("do not lead with Mobile or expose an unusable SMS path"). The toggle is removed; the API retains the SMS channel definition for future use, but the product surface is now honestly email-only.

Reported issue	Root cause	Resolution
"QR scanning not working" / "static QR problem"	Scanner required the native BarcodeDetector API, absent on iPhone Safari	jsQR fallback decoder with rotation retries; native API kept as fast path
Paste-code card confusing and unattractive	Large card led with developer vocabulary (URL formats) and competed with the scan action	"Scan QR" is the single primary button; manual entry demoted to compact card
Greeting stuck on "Good morning"; dislikes "Hello there"	Greeting computed once per render; unnamed users got the literal fallback "there"	Greeting recomputed on interval and visibility change; fallback is now "Friend"
Remove mobile number from login and sign-up	Mobile channel offered without any SMS provider configured	Channel toggle removed; sign-in is email-only end to end

Table 1 — User-reported defects, root causes and shipped resolutions.

3. Audit Findings — Remediation Matrix

The external audit (Perk_Loop_Production_Audit.md, dated 24-25 October 2026) enumerated fourteen findings with priority levels: P0 items block a safe public launch, P1 items must be fixed before the affected workflow is offered, and P2 items improve usability or maintainability. Table 2 records the status of every finding after this session. "Fixed" means the code change is deployed to production; "Deferred" means the item requires a product decision or infrastructure access and is tracked in Section 6.

ID	Pri	Finding	Status	Action taken
F01	P0	Authentication fails open when production config is missing	**Fixed**	Dev OTP codes can never be returned in production (NODE_ENV / VERCEL guard returns 503); loud warning when SESSION_SECRET falls back to the dev value
F02	P0	Concurrent redemptions bypass per-customer limits	**Fixed**	createRedemption runs entirely inside a SERIALIZABLE transaction with write-conflict retry; limit count, pending check and creation are now atomic
F03	P1	Duplicate active programs can be created concurrently	**Fixed**	Program create and activate enforce one-active-per-type inside the same serializable transaction
F04	P1	Merchant settings cannot be saved	**Fixed**	Settings PUT payload now includes the business id; server-side ownership check unchanged
F05	P1	Program start/end dates not enforced	**Fixed**	programLive() gate applied to points earning, stamp earning and redemption creation
F06	P1	Visit-counter programs offered but incomplete	**Fixed**	Creation restricted to STAMPS and POINTS in both UI and API with a friendly message; customer-facing description typo corrected; dead form branches removed
F07	P1	Repeated scans inflate visits and repeat-rate analytics	**Fixed**	Cooldown and no-program scans record an audit-trail attempt only — no Visit row, no visit-count or last-visit update; metrics reflect qualifying visits
F08	P1	A photographed static QR is not proof of presence	**Deferred**	Business-policy decision (fraud tolerance); requires merchant input on visit tokens or approvals
F09	P1	Multi-business support incomplete	**Fixed**	One business per owner for the pilot; second business creation returns an explicit, friendly 409
F10	P1	Dependency versions need security update (Next.js 16.1.3)	**Deferred**	Upgrade planned immediately before pilot; must be validated against the Vercel build and full test suite (see Section 6)

ID	Pri	Finding	Status	Action taken
F11	P1	QR scanning not dependable across browsers	**Fixed**	jsQR pure-JS decoding removes the BarcodeDetector dependency entirely; feature detection still prefers native decoding where available. Real-device camera QA remains open (Section 6)
F12	P1/P2	Pending approvals and account states go stale	**Fixed**	Visible-tab polling added (notifications 15 s, wallet 12 s, merchant queues 15 s); customers can withdraw pending redemptions via a new cancel endpoint; abandoned requests stop blocking after 24 h
F13	P2	Customer FAQ link opens the wrong destination	**Fixed**	Profile FAQ row navigates to the landing page and scrolls to the FAQ section once rendered
F14	P1	Release and recovery controls insufficient	**Deferred**	Requires CI pipelines, migration history and backup drills; infra-level work tracked in Section 6

Table 2 — All fourteen audit findings and their status after commit e0b5d3b.

3.1 How the concurrency fixes work

Findings F02 and F03 shared a root cause: rules were enforced by counting rows and then creating new ones in separate steps, so two simultaneous requests could both observe "no conflict" and both write. The fix introduces a shared transaction helper that runs PostgreSQL transactions at SERIALIZABLE isolation with automatic retry on write-conflict errors, and moves each count-then-create sequence fully inside it. SQLite (used for sandbox previews) serialises writers natively, so the same code path runs there without the isolation flag. This restores a single invariant source in the loyalty engine instead of scattering checks across screens, exactly as the audit recommended.

3.2 How the loyalty engine treats visits now

Previously every scan created a Visit row and incremented the customer visit counter, even when the 30-minute stamp cooldown meant nothing could be awarded. Repeat-rate analytics therefore counted scans, not visits. Now a scan that falls inside the cooldown, or arrives when no eligible program is live, is recorded only in the audit trail with a reason code; no Visit row is created and no counter moves. The earning cooldown is measured from the last qualifying visit, which also stops the old behaviour of rescans repeatedly pushing the next-earnable time further into the future.

4. Layout Integrity and Responsive Repair

The audit's browser matrix found concrete overflow defects: the landing page measured 390 CSS px wide inside a 320 px viewport (70 px of horizontal scroll), the customer desktop shell clipped its top tabs (503 px of tabs inside 446 px), and the merchant dashboard forced horizontal scrolling at 320 px because its two quick-action buttons could not wrap. Each was reproduced, root-caused and repaired in this session.

The landing overflow came from three compounding sources: a fixed-width phone illustration nested inside padded preview cards, a floating "No setup fee" chip that hung outside its card on small screens, and a corrupted CSS mask-image class on the categories rail that had lost its opening bracket. Illustration sections now clip decorative overhang with overflow-x-clip, the phone frame yields with max-width, the chip stays inside its card below the small-screen breakpoint, and the corrupted class was restored. The customer shell widens to 512 px on desktop while the top tabs compacted, so all five tabs fit without clipping. Table 3 shows measured before-and-after values.

Surface	Audit measurement	After remediation
Landing page, 320 px viewport	Document 390 px wide — 70 px horizontal scroll	Document exactly 320 px — zero overflow
Landing page, 360 px viewport	Document 390 px wide — 30 px horizontal scroll	Document exactly 360 px — zero overflow
Customer app, desktop ≥768 px	Tabs 503 px inside 446 px shell — ends clipped	Shell 512 px with compact tabs — all five visible
Merchant dashboard, 320 px	Quick actions exceeded the viewport	Actions wrap; no horizontal scroll
Customer bottom nav, iPhone	No safe-area padding below the bar	Respects safe-area insets
Landing hero, 390 px	Floating nav overlapped the hero badge	Hero clears the fixed nav

Table 3 — Measured responsive defects and verified results.

5. Verification and Test Evidence

Every change passed through the same gate sequence: a clean TypeScript compile (tsc --noEmit), a clean ESLint run, the full backend end-to-end suite against a freshly seeded database, and a scripted Chromium session that exercised the real user journeys. The backend suite is the repository's own 31-assertion harness covering OTP registration and login, code reuse rejection, feedback duplication control, earning via both QR types, redemption limits, merchant approval, notification creation and analytics aggregates. It completed with 31 passes and 0 failures after the loyalty-engine rewrite — including the analytics aggregate test, which now reflects qualifying visits only.

5.1 Browser end-to-end session

The browser session signed in with a crafted session for the seeded demo customer, then verified each fix on the rendered screen: the home greeting read "Good afternoon, Aarav" with all five desktop tabs fully visible; the Scan tab showed the new "Scan QR" layout; the native BarcodeDetector API was then deliberately deleted from the page to simulate iPhone Safari, and a real QR photograph (generated at 400 px, encoding a live outlet deep link) was uploaded through the file input. The jsQR path decoded it and the app navigated to the correct outlet screen showing "Reward Jar Demo Café" with its check-in panel, which is the exact journey that previously failed on the owner's phone. The email-only sign-in screen was screenshot-verified, and the browser error console stayed empty throughout.

Gate	Command / method	Result
Type safety	tsc --noEmit	Clean — 0 errors
Lint	eslint .	Clean — 0 errors
Backend suite	bun scripts/e2e-backend.ts (fresh seed)	31 passed, 0 failed
Browser E2E	Chromium session: login, home, scan, QR photo decode, auth screen	All journeys pass; console clean
Small-viewport audit	320 px and 360 px document-width probes	scrollWidth == viewport at both widths
Production build	Vercel build for commit e0b5d3b	Success
Production smoke	Live URL probe + console + 320 px probe	No errors; no overflow; assets fresh

Table 4 — Verification gates and outcomes for release e0b5d3b.

6. Deferred Items and Recommendations

Two audit findings and one residual risk were deliberately deferred rather than forced into this session, because fixing them properly requires either a product decision or controlled infrastructure work that cannot be validated from this environment. Each is listed with its rationale and the recommended next step so it can be scheduled deliberately instead of being forgotten.

F08 — photographed QR is not proof of presence. A saved photo of a counter QR can still be replayed after the cooldown from anywhere. Deciding the fraud tolerance is a merchant conversation: options range from accepting the risk for low-value stamps, to merchant-issued short-lived visit tokens for valuable rewards. Recommend deciding the policy with the first pilot shops before enabling high-value rewards.

F10 — dependency security update. The audit flags Next.js 16.1.3 against the 14 October 2026 security advisory (patched in 16.4.1). The upgrade was deferred deliberately: a framework version jump must be validated against the Vercel build and the full test suite, and bundling it with eleven other fixes would make any regression hard to attribute. Recommend running the upgrade as its own change: bump, build, run the 31-test suite and the browser session, then deploy.

F14 — release and recovery infrastructure. Migrations history, CI gates, backup drills and a readiness probe are operational work on the GitHub/Vercel/Supabase side. The audit's Stage-2 plan is a sound template: create a reviewed migration baseline, add CI (frozen install, lint, typecheck, build, tests), verify Supabase Data API lockdown is applied live, and rehearse one backup restore. Also scheduled for real-device QA: physical iPhone Safari and Android Chrome camera journeys, which browser emulation cannot fully certify.

Two operational notes from this session are worth recording. First, a platform file-restore rolled the local working copy and git history back to a 20 October checkpoint mid-session; the repository was recovered from the GitHub remote with no loss (the remote and production were unaffected), and local environment secrets were re-entered. Second, the production deployment now requires the SMTP and SESSION_SECRET variables to remain set in Vercel; the application warns loudly but does not crash if they are missing, and OTP delivery fails closed with a 503 rather than ever exposing a code.

7. Deployment Record

The release is a single commit built on the remediation of the previous session's logo swap. It was pushed to the main branch, picked up by the Vercel Git integration, built successfully on the first attempt, and verified live. The production URL serves the updated bundle; a post-deploy smoke probe confirmed a clean console, fresh assets, and zero horizontal overflow at 320 px.

Event	Detail
Remediation commit	e0b5d3b — "fix: production-audit remediation + user-reported UX fixes"
Parent commit	bcaa609 — jar logo swap (previous session)
Push	bcaa609..e0b5d3b, main → github.com/sahilnegi1/perkloopbyzlm
Build	Vercel production build — success
Live URL	https://perkloopbyzlm-jobbuddies.vercel.app (canonical production)
Post-deploy smoke	No console errors; document width 320 px at 320 px viewport

Table 5 — Release record for the remediation deployment.

With this release the Reward Jar pilot stack is materially closer to the audit's Stage-1 exit condition: no unresolved P0 findings remain in code, and every P1 finding tied to a workflow that the pilot will

exercise has been repaired. The remaining items are deliberate, scheduled work rather than open defects.